

# Полный аудит проекта

Дата: 25.06.2026 · Production: **sonogyn-pro.ru** · Коммит: `ff72e8e` (main)  
Health API: 200 OK · GitHub CI #91 — success

## 1. Сводка «готово / не готово»

| Область                  | Готово                                                       | Не готово / риск                          |
|--------------------------|--------------------------------------------------------------|-------------------------------------------|
| Web-клиника              | ~99 страниц, пациенты, протоколы, PDF, калькуляторы          | Часть API без Zod (~65%)                  |
| Auth                     | Email, Google, SMS, Telegram, MFA, Turnstile                 | SMS e2e на prod не прогнан                |
| Образование              | 10+ модулей library, quiz, cases                             | i18n (en/es) — не начато                  |
| Сосудистое УЗД (Куликов) | Гл. 1–9, AI, печать, 33 Q, 9 cases                           | Mobile parity = 0                         |
| Mobile (Ехро)            | O-RADS, FMF, калькуляторы, offline UI                        | EAS build, push pilot, magic bytes upload |
| Безопасность             | RLS, rate limits, security headers, migration 20260608120000 | Zod не на всех API; mobile upload         |
| CI/CD                    | typecheck, lint, build, CPI e2e                              | Полный Playwright только CPI              |
| Монетизация              | Stripe + YooKassa webhooks                                   | Пилот подписки не замерен                 |
| AI-сервисы               | O-RADS, TI-RADS, breast, vascular, CPI                       | Railway worker — отдельный деплой         |

## 2. Web — клинические модули

### Закрыто

| Модуль                     | URL                 | Статус                        |
|----------------------------|---------------------|-------------------------------|
| Hub помощника              | /assistant          | 4 сценария + workspace        |
| O-RADS / BI-RADS / TI-RADS | /calculators/*      | Калькуляторы + AI assist      |
| FMF (Медведев)             | /assistant/fmf      | I–III скрининг, доплер, шейка |
| CPI (шейка)                | /cpi/*              | IFCPC, HPV, Swede, CDS, AI    |
| Сосудистое УЗД             | /assistant/vascular | Полный цикл Куликов           |
| Пациенты / кейсы           | /patients, /cases   | CRUD + обсуждения             |
| LMS (автор)                | /author/courses     | Видео multipart, модули       |
| Evidence                   | /evidence           | SonoEvidence v1, 235 тем      |

| Модуль      | URL       | Статус             |
|-------------|-----------|--------------------|
| Discussions | web + API | Q&A, push webhooks |

#### Частично / техдолг

| Модуль          | Что есть           | Что не доделано                           |
|-----------------|--------------------|-------------------------------------------|
| Breast ARFI     | Калькулятор        | Качественная ARFI, m/s, JSON data service |
| FMF percentiles | UI + расчёты       | Валидация vs официальные таблицы FMF      |
| Library catalog | vascular badge NEW | Описание «3 случая» устарело (сейчас 9)   |
| PDF snapshot    | Работает           | XSS-аудит highlightText — перепроверять   |

### 3. Сосудистое УЗД (Куликов)

Закрыто (production, ff72e8e)

| Глава   | Клиника                              | Образование         |
|---------|--------------------------------------|---------------------|
| 1–3     | —                                    | Карточки ординатора |
| 4 БЦА   | BcaProtocolPanel, стеноз ВСА         | Quiz + cases        |
| 5 TCD   | TcdProtocolPanel, Lindegaard         | Quiz q31            |
| 6 АНК   | LowerLimbArteriesProtocolPanel, ИПС  | Quiz                |
| 7 ВНК   | LowerLimbVeinsProtocolPanel, рефлюкс | Quiz + case ТГВ     |
| 8 ВК    | UpperLimbProtocolPanel, AV-фистула   | Quiz q32            |
| 9 Аорта | AAA, RAR, ЭКЧС                       | Quiz q28–30         |

AI `/api/ai/vascular-assist` : basin metrics, carotid grade, rate limit, Zod body.

UI AI-вкладка: PSV БЦА, ЭКЧС (ЧС вдох/выдох), сегмент рефлюкса.

Печать: `print-protocol.ts` → кнопка на вкладке «Протокол».

#### Не сделано (сосуды)

- Mobile-модуль сосудов
- Unit-тесты `vascular-basin-metrics` (нет vitest в web)
- Экспорт PDF протокола (только print/copy)
- Quiz 34+ (опционально)

### 4. Auth и безопасность

#### Закрыто

- Методы: telegram | email | phone | social (Google)
- Middleware: session, RBAC, bot block, SMS 3/min на IP
- Migration: `20260608120000_security_hardening.sql`
- Web upload: magic bytes (`file-validation.ts`)
- Rate limits: auth, AI, patients, payments
- Telegram OTP — primary channel (коммит 1452639)

#### Открыто — чеклист самопроверки

| # | Проверка                 | Ожидание                             |
|---|--------------------------|--------------------------------------|
| 1 | XSS highlightText        | Экранирование, без выполнения script |
| 2 | ILIKE escape в поиске    | Без wildcard injection               |
| 3 | IDOR patient/study       | 401/403 без сессии                   |
| 4 | Upload magic bytes (web) | 400 reject для подмены расширения    |
| 5 | Rate limit AI            | 429 при flood                        |
| 6 | Zod coverage             | ~37/107 routes — расширять           |

### **Mobile security gaps**

- Upload без magic bytes (mobile server, Firebase cases)
- SecureStore — частичная миграция с AsyncStorage
- 24h offline → принудительный sign-out

## 5. Mobile vs Web

| Функция              | Web | Mobile          |
|----------------------|-----|-----------------|
| O-RADS AI            | ✓   | ✓ (beta events) |
| FMF                  | ✓   | ✓               |
| Vascular Kulikov     | ✓   | ✗               |
| CPI                  | ✓   | частично        |
| Discussions + push   | ✓   | e2e не прогнан  |
| Offline калькуляторы | ✗   | ✓               |
| Telegram auth        | ✓   | ✓               |

### Пилот (TODO.md):

- Auth SMS end-to-end (sms.ru, TTL 10 мин)
- EAS build preview/production + push tokens
- Discussions e2e web + mobile

## 6. Тесты и CI

| Тип             | Файлов               | CI                  |
|-----------------|----------------------|---------------------|
| Unit (packages) | ~47                  | CPI module tests    |
| Playwright e2e  | 7 specs              | только test:e2e:cpi |
| Mobile unit     | O-RADS, elastography | не в CI             |

Команды: `pnpm typecheck`, `pnpm lint`, `pnpm test:cpi`, `cd apps/web && pnpm test:e2e`

## 7. Deploy / infra

| Сервис               | Статус | Примечание                       |
|----------------------|--------|----------------------------------|
| Vercel               | ✓      | auto-deploy main, cron 06:00 UTC |
| Supabase             | ✓      | 72 migrations, RLS               |
| Railway us-ai-worker | ⚠      | отдельный деплой                 |
| GitHub CI            | ✓      | run #91 success                  |
| Домены               | ✓      | sonogyn-pro.ru, www → 301        |

## 8. Продуктовые цели

| Цель (3 мес.)         | Статус                      |
|-----------------------|-----------------------------|
| Релиз mobile          | EAS build не завершён       |
| Запуск сайта          | production live             |
| FMF таблицы Медведева | нужна валидация percentiles |

| Цель (3 мес.)   | Статус                    |
|-----------------|---------------------------|
| Пилот 2–3 врача | доступ есть, feedback = 0 |
| 10k подписчиков | не начато                 |

## 9. Закрыто / открыто / вне scope

| Задача                           | Статус                           |
|----------------------------------|----------------------------------|
| Vascular гл. 4–9 клиника + AI    | ✓                                |
| Vascular education 33 Q, 9 cases | ✓                                |
| Vascular print protocol          | ✓                                |
| Vascular mobile                  | ✗                                |
| Auth Telegram primary            | ✓                                |
| Security migration 20260608      | проверить apply на Supabase prod |
| Zod all API routes               | ✗                                |
| Full Playwright in CI            | ✗                                |
| i18n en/es/fr                    | ✗                                |
| ARFI breast qualitative          | ✗                                |
| Phase 3 O-RADS chat/share        | ✗                                |
| App Store / Google Play release  | ✗                                |

## 10. Рекомендуемые следующие шаги

1. **Пилот (1–2 дня):** SMS auth + discussions push на физ. устройстве
2. **Supabase prod:** убедиться, что migration 20260608120000 применена
3. **CI:** расширить e2e → auth.spec.ts + vascular smoke
4. **Catalog fix:** обновить описание vascular (9 cases, 33 Q)
5. **Mobile:** vascular norms + экран стеноза BCA (MVP)
6. **Zod wave:** patients, cases, auth routes

## 11. Smoke production

| URL                          | HTTP        | Комментарий           |
|------------------------------|-------------|-----------------------|
| /login                       | 200         | ОК                    |
| /assistant/vascular          | 307 → login | ожидаемо              |
| /library/vascular-ultrasound | 307 → login | ожидаемо              |
| /api/health                  | 200         | status: ok            |
| /api/ai/vascular-assist POST | 403         | без сессии — ожидаемо |

Отчёт сформирован автоматически по состоянию кодовой базы SonoGyn Pro (monorepo).  
Клинические пороги — по Куликов 2015 и локальному протоколу клиники. Не заменяет формальный pentest.  
Интерпретация — лечащим специалистом. Не является диагнозом.